

Qantas Supply Chain Breach

2025

Fallstudie eines Identity-First Supply Chain Angriffs

Einordnung & Kontext

Angriffstyp

- **Supply-Chain-Angriff**
- Partner-Kompromittierung
- Identity-First Vektor
- Implicit Trust Exploitation

Betroffene Systeme

- Qantas CRM-Backend
- Vielflieger-Datenbank
- ~6 Mio. Kundendatensätze
- BPO-Partner (Philippinen)

Kernproblem: Vertrauen ohne Verifikation (Implicit Trust Relationships)

Das Ökosystem

Ziel

- Qantas CRM-Backend
- Vielflieger-Stammdaten
- Sensible PII-Daten

Einstiegspunkt

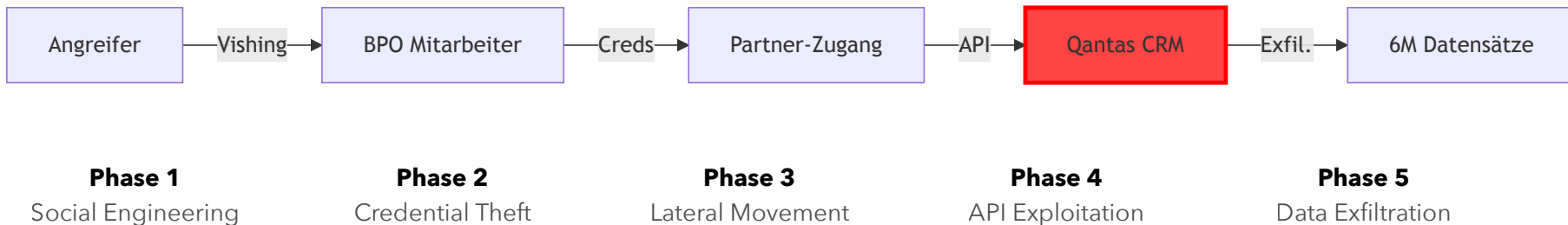
- BPO-Dienstleister
- Philippinisches Callcenter
- Legitimer Partner-Zugang

Bedrohungsakteur

Profil

- Finanziell motiviert
- Scattered Spider (vermutet)
- Hochentwickeltes Social Engineering
- Spezialisiert auf Identity-Angriffe

Attack Flow



Initial Access: Social Engineering

Vishing (Voice Phishing)

- Telefon-basierter Angriff
- Zielpersonen: Callcenter-Mitarbeiter
- Psychologischer Druck
- **Credential Harvesting**

Credential Harvesting: Systematisches Sammeln von Anmeldedaten durch Social Engineering oder technische Mittel

MFA-Umgehung

MFA-Fatigue

- Push-Notification-Flooding
- Nutzer-Erschöpfung
- Unaufmerksame Bestätigung

Warum funktioniert das?

- Menschliche Schwäche
- Keine Kontextprüfung
- Phishable MFA (Push/SMS)

API-Schwachstelle: BOLA

Broken Object Level Authorization

OWASP API Security #1

- **Problem:** Server prüft WER, nicht WORAUF
- Fehlende Autorisierung auf Objekt-Ebene
- Nur Authentifizierung, keine Ownership-Prüfung

Exploitation

```
GET /api/customer/12345  
Authorization: Bearer <partner_token>
```

```
GET /api/customer/12346  
GET /api/customer/12347
```

ID-Enumeration

Methode

- Systematisches Durchprobieren
- Skript-gesteuert
- Sequentielle IDs

```
for id in range(1, 10000000):  
    fetch(f"/api/customer/{id}")
```

Massen-Exfiltration

Fehlende Sicherheitskontrollen

Kein Rate Limiting

Begrenzung der Anfragen pro Zeiteinheit fehlt

Kein Throttling

Keine Drosselung bei verdächtigem Verhalten

Keine Anomalie-Erkennung

Massenhafte API-Calls unbemerkt

Mass Assignment

Skript-gesteuerter Datenabzug:

- Millionen von Datensätzen in Stunden
- Automatisierte Enumeration
- Tarnung durch autorisierten Partner-Kanal

Schadensanalyse

Datenumfang

- **6 Millionen** Kundendatensätze
- Namen, Geburtsdaten, E-Mails
- Telefonnummern
- Vielflieger-Status

PII & Identity Starter Kits

Personally Identifiable Information

- Name + DOB + E-Mail = "Starter Kit"
- Ermöglicht Identitätsdiebstahl
- Basis für Spear-Phishing

Regulatorische Folgen

Australian Privacy Act

- Meldepflicht bei Data Breaches
- Drakonische Strafen bei Fahrlässigkeit
- Reputationsschaden

Wirtschaftlicher Schaden

- Forensik & Incident Response
- Rechtsberatung & Compliance
- Kundenkommunikation
- Marktwert-Verlust

Lessons Learned

Technische & organisatorische Gegenmaßnahmen

Prävention: FIDO2 & WebAuthn

Phishable MFA (Problem)

- SMS-basiert
- Push-Notifications
- Time-based Codes (TOTP)

Schwächen:

- Anfällig für Social Engineering
- Session Hijacking möglich

FIDO2/WebAuthn (Lösung)

- Kryptografie mit öffentlichem Schlüssel
- Hardware-gebundene Authentifizierung
- Physischer Sicherheitsschlüssel

Vorteile:

- Technisch unphishbar
- Kein Credential Theft möglich

Wie funktioniert FIDO2? Challenge-Response mit privatem Schlüssel – der Schlüssel verlässt nie das Hardware-Token

Zero Trust Architecture

"Never Trust, Always Verify"

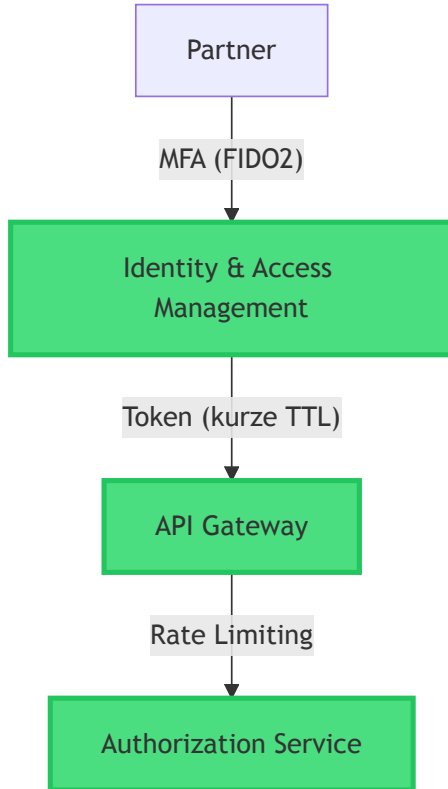
Traditionelles Modell

- Perimeter-basierte Sicherheit
- Implizites Vertrauen nach Login
- Pauschale Partner-Zugänge
- "Inside vs. Outside" Denken

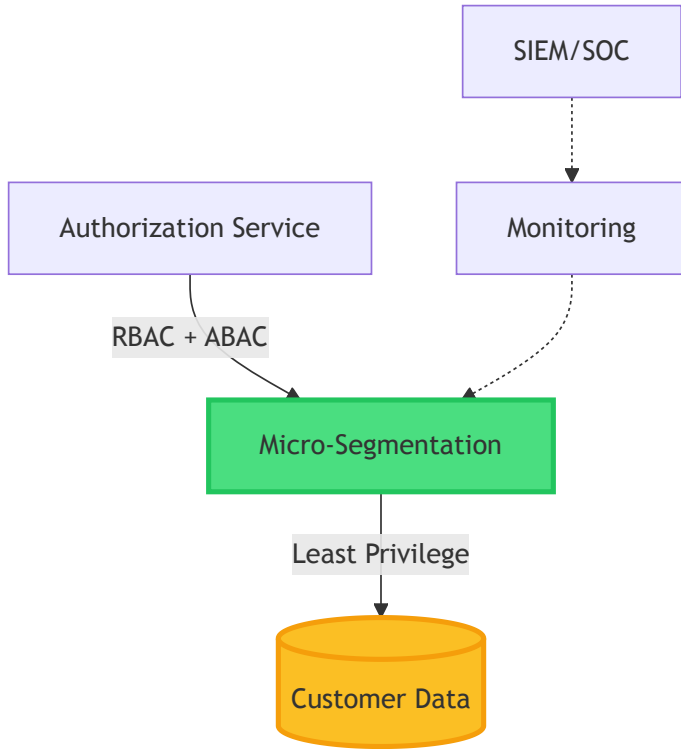
Zero Trust Modell

- Continuous Verification
- Kein implizites Vertrauen
- Micro-Segmentation
- Least Privilege Prinzip

Technische Architektur: Übersicht



Technische Architektur: Data Layer



Fazit

Identität ist der neue Sicherheitsperimeter

Supply Chain Risk Management ist kritische Infrastruktur

Technik muss menschliches Versagen antizipieren

Kernerkenntnisse

FIDO2 ist Pflicht

Phishable MFA ist obsolet

Zero Trust umsetzen

Kein implizites Vertrauen

API Security

BOLA & Rate Limiting prüfen

Danke für die Aufmerksamkeit

Fragen?

Quellen

Incident Reports & News

- Qantas Official Statement: qantasnewsroom.com.au
 - Update Statement: [Detailed Informations](#)
- CM Alliance Analysis: [Qantas Data Breach - Scattered Spider](#)
- Cybersecurity News: [Qantas Airlines Cyberattack](#)
- Australian Cyber Security Magazine: [Stolen Records on Dark Web](#)
- Altexsoft: [Qantas Data Breach](#)

Regulatory & Compliance

- OAIC Statement: [Statement on Qantas Cyber Incident](#)
- OAIC: [Notifiable Data Breaches](#)
- LawFuel: [Qantas Privacy Complaint After Data Breach](#)

Technical References

- IBM: [Data Breach Topics](#)
- OWASP API Security: [Broken Object Level Authorization](#)
- Tech Radar: [Spider Hackers](#)